

NEXCORT iQ · INTERNAL PRODUCT REQUIREMENTS

Security, CJIS & SOC 2 Alignment Statement

Agency-facing security posture for IT, procurement, and pilot review. Not a certification.

Legal entity: Apps on Demand LLC (Wyoming) · Product: NexCort iQ · Marketing: www.nexcortiq.us · Ops: app.rapidcortex.us · (404) 520-1747 · jeff@nexcortiq.us

Positioning

NexCort iQ is a decision-support intelligence layer for emergency communications and related verticals (campus, venue, transit, hospital, Call Assist). It is not a replacement for CAD, telephony, radio consoles, medical direction, law enforcement databases, or dispatcher judgment.

Say this / do not say this

Topic	Say	Do not say
CJIS	Designed with CJIS alignment — RBAC, audit logging, MFA, encryption at rest and in transit.	We are CJIS certified.
SOC 2	SOC 2 Type II documentation corpus is substantially complete; formal CPA certification is in progress (target early 2027).	We are SOC 2 certified.
AI	Every AI recommendation is shown for human review. AI does not take action autonomously.	AI handles it automatically.
CAD write-back	Fail-closed by default. Enabled only after a signed agency addendum and explicit configuration.	Write-back is included in every pilot.
Data residency	Primary production data in AWS us-east-1. We do not imply offshore routing.	Multi-cloud or unspecified residency.

Core controls

Area	Pilot requirement	Production target
Identity	Amazon Cognito, MFA, least-privilege RBAC via custom:role, inactive accounts blocked.	SSO/SAML-OIDC, 60-day password rotation, quarterly access reviews, break-glass procedure.
Tenant isolation	agencyId on every DynamoDB read/write; AuthorizationService.canPerform at handler entry.	Automated cross-tenant tests in CI; dual-admin Agency Share only when enrolled.
Encryption	TLS in transit; KMS/AWS-managed encryption at rest for DynamoDB, S3, media.	Customer-managed KMS option for enterprise; media encrypted separately.
Audit	Meaningful state changes emit audit events (user, agency, action, timestamp). Failures never abort business logic.	Exportable reports, 7-year retention on government compliance records, CAD write-back audit trail.
Media	Expiring links, no public buckets, recording off unless configured.	Configurable retention, legal hold, evidence export workflow.
Monitoring	CloudWatch alarms, WAF logs, structured error tracking. Never log JWT, PII, or CAD payloads.	SIEM hook + documented 24/7 incident response path.
Vendors	Document AWS (Bedrock, Transcribe, Translate, KVS, SES/SNS), SMS 10DLC (+1 319-835-8230).	Annual vendor review and security addenda.

CJIS alignment notes

- Treat CJIS as an alignment target unless the agency formally validates the environment.
- Keep NCIC and CJIS-protected query data out of early pilots unless separately approved.
- Application logs must not contain raw transcripts, prompts, media URLs, or CAD data.
- This statement does not prove personnel screening, physical security, or agency-specific CJIS accreditation.

SOC 2 readiness notes

- Maintain written policies: access control, change management, incident response, vendor risk, DR, retention.
- Collect evidence continuously: deploy logs, access reviews, alarm configs, backup tests, security scans.
- Do not market SOC 2 certified until a CPA audit is complete.